Ley que regula la divulgación coordinada de vulnerabilidades y protege a los investigadores de seguridad de buena fe

Modifica el artículo 12 de la Ley 30096 para eximir de responsabilidad penal a quien investiga y reporta vulnerabilidades de buena fe conforme a una política pública, obliga a las entidades públicas a publicar políticas de divulgación y habilita programas de recompensas (bug bounty) en el Estado.

Comisión sugerida: Justicia y Derechos Humanos (+ Ciencia, Innovación y Tecnología) · **Prioridad:** media · **Costo fiscal:** nulo · **Plazo:** corto

Plan Perú 2050: Ciber Seguridad, Capital Del Conocimiento

I. Exposición de motivos

El artículo 12 de la Ley 30096, incorporado por la Ley 30171, exime de responsabilidad penal solo a quien realiza pruebas autorizadas para proteger sistemas informáticos. Un ciudadano o investigador que detecta una falla en un portal público y la reporta sin autorización previa queda expuesto a una denuncia por acceso ilícito (artículo 2), lo que desincentiva el reporte y favorece que las vulnerabilidades se vendan o exploten. El Decreto Supremo 126-2025-PCM incluye entre los deberes de los proveedores la realización proactiva de pruebas de vulnerabilidades (Apaxi, 2026), pero no existe un canal legal para que terceros reporten de buena fe ni obligación de las entidades públicas de tener una política de divulgación. En Estados Unidos, la directiva BOD 20-01 obligó a las agencias federales a publicar políticas de divulgación; ENISA documenta la adopción de políticas nacionales de divulgación coordinada en la Unión Europea, y NIS2 encarga a los CSIRT actuar como coordinadores. Contar con estas reglas aprovecha el talento local en ciberseguridad a bajo costo.

II. Fórmula legal

EL CONGRESO DE LA REPÚBLICA ha dado la Ley siguiente:

LEY QUE REGULA LA DIVULGACIÓN COORDINADA DE VULNERABILIDADES Y PROTEGE A LOS INVESTIGADORES DE SEGURIDAD DE BUENA FE

Artículo 1. Objeto

La presente ley tiene por objeto regular la divulgación coordinada de vulnerabilidades en sistemas informáticos, proteger a los investigadores de seguridad que actúan de buena fe y promover programas de recompensas en las entidades públicas.

Artículo 2. Modificación del artículo 12 de la Ley 30096

Modifícase el artículo 12 de la Ley 30096, en los siguientes términos: "Artículo 12. Exención de responsabilidad penal. Está exento de responsabilidad penal el que realiza las conductas descritas en los artículos 2, 3, 4 y 10: a) con el propósito de llevar a cabo pruebas autorizadas u otros procedimientos autorizados destinados a proteger sistemas informáticos; o b) con el propósito exclusivo de identificar y reportar una vulnerabilidad, siempre que actúe conforme a la política de divulgación del titular del sistema o, en su defecto, a la política nacional de divulgación coordinada, no cause daño, no extraiga ni conserve datos más allá de lo necesario para demostrar la vulnerabilidad, la reporte sin demora y no la divulgue públicamente antes del plazo de corrección."

Artículo 3. Política nacional de divulgación coordinada

El Centro Nacional de Seguridad Digital, o el órgano que haga sus veces, aprueba y publica la política nacional de divulgación coordinada de vulnerabilidades, actúa como coordinador entre investigadores y titulares de sistemas y puede mantener la reserva de la identidad del investigador que lo solicite.

Artículo 4. Políticas de divulgación en entidades públicas

Las entidades de la administración pública publican en su sede digital una política de divulgación de vulnerabilidades con un canal de reporte, el alcance de los sistemas incluidos, los compromisos de respuesta y el plazo de corrección, conforme al formato que apruebe el Centro Nacional de Seguridad Digital.

Artículo 5. Plazos de respuesta

La entidad que recibe un reporte acusa recibo en un plazo no mayor de 5 días hábiles y corrige o mitiga la vulnerabilidad en un plazo no mayor de 90 días calendario, prorrogable por razones técnicas debidamente justificadas ante el Centro Nacional de Seguridad Digital.

Artículo 6. Programas de recompensas

Las entidades públicas pueden implementar programas de recompensas por vulnerabilidades, directamente o a través de plataformas especializadas, con cargo a su presupuesto institucional. El pago de recompensas se considera contraprestación por servicios y se rige por las reglas que apruebe el reglamento, en concordancia con la normativa de contrataciones del Estado.

Artículo 7. Prohibición de represalias

Ninguna entidad pública puede iniciar acciones administrativas, civiles o penales contra el investigador que cumpla las condiciones del literal b) del artículo 12 de la Ley 30096.

Artículo 8. Sector privado

Se promueve la adopción voluntaria de políticas de divulgación en el sector privado. Los operadores de servicios esenciales están obligados a adoptarlas.

Primera. Disposición Complementaria Final

Reglamentación. El Poder Ejecutivo, mediante decreto supremo refrendado por el Presidente del Consejo de Ministros y el Ministro de Justicia y Derechos Humanos, reglamenta la presente ley en un plazo no mayor de 90 días hábiles contados desde su entrada en vigencia.

Segunda. Disposición Complementaria Final

Plazo de adecuación. Las entidades del Poder Ejecutivo publican sus políticas de divulgación en un plazo de 6 meses y los gobiernos regionales y locales en un plazo de 18 meses desde la aprobación de la política nacional.

Tercera. Disposición Complementaria Final

Financiamiento. La implementación de la presente ley se financia con cargo al presupuesto institucional de las entidades involucradas, sin demandar recursos adicionales al Tesoro Público.

III. Análisis costo-beneficio

Costo fiscal nulo a bajo: publicar una política y un canal de reporte tiene costo marginal; los programas de recompensas son facultativos y se financian con presupuesto institucional. El beneficio es identificar vulnerabilidades antes de que sean explotadas, a un costo muy inferior a la respuesta ante un incidente. La reforma del artículo 12 da seguridad jurídica a la comunidad técnica sin crear una licencia para atacar: exige buena fe, ausencia de daño, minimización de datos y reporte inmediato. El riesgo de abuso se mitiga porque la exención no alcanza la extracción o conservación indebida de datos.

IV. Efecto de la vigencia de la norma

Modifica el artículo 12 de la Ley 30096 (incorporado por la Ley 30171); complementa el Decreto de Urgencia 007-2020 y el Decreto Supremo 126-2025-PCM.

V. Indicador de éxito al 2031

A 2029, 100 % de ministerios y organismos públicos del Poder Ejecutivo con política de divulgación publicada; informe anual del CNSD sobre vulnerabilidades reportadas y corregidas.

Normas relacionadas

• Ley 30171, Ley que modifica la Ley 30096 (incorpora el artículo 12, exención por pruebas autorizadas) — https://www.leyes.congreso.gob.pe/Documentos/Leyes/30171.pdf

• Ley 30096, Ley de Delitos Informáticos (2013) — https://busquedas.elperuano.pe/dispositivo/NL/1003117-1

• Decreto Supremo 126-2025-PCM, Reglamento del Decreto de Urgencia 007-2020 (Marco de Confianza Digital) — https://busquedas.elperuano.pe/dispositivo/EX/2455024-1

• Decreto de Urgencia 007-2020, que aprueba el Marco de Confianza Digital y dispone medidas para su fortalecimiento — https://www.gob.pe/institucion/pcm/normas-legales/395322-007-2020

Antecedentes

Por verificar en SPLEY.

Referencias internacionales

• Estados Unidos: CISA Binding Operational Directive 20-01: políticas de divulgación de vulnerabilidades en agencias federales — https://www.cisa.gov/news-events/directives/bod-20-01-develop-and-publish-vulnerability-disclosure-policy

• Unión Europea: ENISA: Coordinated Vulnerability Disclosure Policies in the EU — https://www.enisa.europa.eu/publications/coordinated-vulnerability-disclosure-policies-in-the-eu

• Reino Unido: NCSC: política de reporte de vulnerabilidades — https://www.ncsc.gov.uk/information/vulnerability-reporting

• Unión Europea: Directiva (UE) 2022/2555 (NIS2), medidas para un elevado nivel común de ciberseguridad — https://eur-lex.europa.eu/eli/dir/2022/2555/oj

Fuentes

• Apaxi (07-09-2026): Normas de ciberseguridad para empresas en el Perú — https://apaxi.info/2026/09/07/normas-ciberseguridad-empresas-peru/

• gob.pe: Reportar incidentes de seguridad digital (Centro Nacional de Seguridad Digital) — https://www.gob.pe/14084-reportar-incidentes-de-seguridad-digital

• Texto del DS 126-2025-PCM (copia LP Derecho) — https://img.lpderecho.pe/wp-content/uploads/2025/11/Decreto-Supremo-126-2025-PCM-LPDerecho.pdf

Propuesta ciudadana de libre uso — no es un proyecto presentado. Versión web: https://unimauro.github.io/agenda-legislativa-tech/p/CIB-11.html